Analyse des sous-traitants — Lidl Collect (Art. 28 RGPD)

> Référence : Art. 28 RGPD (Sous-traitant) Dernière mise à jour : 2026-04-16

PÉRIMÈTRE

L'article 28 du RGPD impose qu'un contrat spécifique — l'Accord de traitement des données (DPA) — soit conclu avec chaque prestataire traitant des données personnelles pour le compte du responsable de traitement. Trois prestataires tiers ont été identifiés dans l'architecture Lidl Collect. Aucun transfert de données hors de l'Union européenne n'a été identifié : le cadre des clauses contractuelles types (CCT/DPF) n'est pas mobilisé.

CARTOGRAPHIE DES SOUS-TRAITANTS

Sous-traitant #1 : Supabase (Hébergement base de données)

CHAMP	VALEUR
Rôle	Hébergeur de la base de données PostgreSQL
Qualification RGPD	**Sous-traitant** au sens de l'Art. 28. Supabase héberge et stocke les données personnelles pour le compte du projet, sans en déterminer les finalités.
Données traitées	Toutes les données personnelles stockées en base : profils clients, commandes, données employés, consentements, journaux d'audit
Localisation des serveurs	**Frankfurt, Allemagne (UE)**
Transfert hors UE	**Aucun.** Données hébergées en UE, aucune réplication hors Union européenne.
DPA disponible	**Oui.** DPA standard disponible sur **supabase.com/privacy**, compatible RGPD.
Certifications	SOC 2 Type 2, ISO 27001 (via infrastructure AWS Frankfurt)
Chiffrement	AES-256 au repos, TLS en transit
Sauvegardes	Sauvegardes chiffrées AES-256 en continu (WAL) et physiques périodiques, hébergées dans la même région Frankfurt.
Risque résiduel	Une demande d'effacement (Art. 17) supprime la donnée en base active, mais les sauvegardes techniques conservent une copie jusqu'à leur expiration. En cas de restauration depuis un point antérieur à une demande d'effacement, les suppressions concernées doivent être ré-appliquées manuellement avant remise en service. Procédure documentée. L'utilisateur est informé du délai résiduel de sept jours dans l'email de confirmation d'effacement.
Statut conformité	✅ **Conforme.** DPA disponible, données en UE, chiffrement AES-256.

Sous-traitant #2 : Brevo Transactional Email API v3

CHAMP	VALEUR
Rôle	Envoi des notifications transactionnelles par email (confirmation de commande, commande prête, confirmation d'effacement, double opt-in, réinitialisation du mot de passe)
Qualification RGPD	**Sous-traitant** au sens de l'Art. 28. Brevo traite les adresses email et le contenu des notifications pour le compte du projet.
Données traitées	Adresse email du destinataire, prénom (personnalisation), contenu de la notification (type de commande, statut)
Provider retenu	**Brevo** (Sendinblue SAS, société française, Paris)
Localisation des serveurs	UE — datacenters AWS eu-west-1 (Irlande, EEE) et infrastructure propre France
Transfert hors UE	**Aucun.** Données hébergées dans l'EEE.
DPA disponible	**Oui.** DPA signable depuis l'interface Brevo. **Action requise : signer le DPA avant mise en production.**
Justification du choix	L'option auto-hébergée a été écartée en raison de la complexité de configuration et de l'absence de SLA, injustifiée pour un prototype. La conformité repose sur la localisation des serveurs (EEE) et l'existence d'un DPA signable — non sur la nationalité du prestataire.
Statut conformité	✅ **Conforme** sous réserve de signature du DPA

Sous-traitant #3 : Brevo Transactional SMS API v3

CHAMP	VALEUR
Rôle	Envoi de SMS automatiques liés au service (confirmation courte, notification commande prête, rappel de retrait, alerte changement de statut)
Qualification RGPD	**Sous-traitant** au sens de l'Art. 28. Brevo traite les numéros de téléphone et le contenu des SMS pour le compte du projet.
Données traitées	Numéro de téléphone du destinataire, contenu du SMS (statut commande, code de retrait)
Provider retenu	**Brevo Transactional SMS** — même écosystème que le service email
Localisation des serveurs	UE — même infrastructure que le service email Brevo
Transfert hors UE	**Aucun** côté Brevo. Note : le SMS transite ensuite par les opérateurs mobiles (Orange, SFR, etc.), hors périmètre RGPD du traitement applicatif.
DPA disponible	**Oui.** Couvert par le même DPA Brevo que le service email — un seul contrat à signer.
Point de vigilance	Les communications transactionnelles (notifications commande) doivent être strictement séparées des communications promotionnelles dans la configuration Brevo.
Statut conformité	✅ **Conforme** sous réserve de signature du DPA

TABLEAU RÉCAPITULATIF

SOUS-TRAITANT	QUALIFICATION	LOCALISATION	DPA	TRANSFERT HORS UE	STATUT
Supabase	Sous-traitant Art. 28	Frankfurt, UE ✅	Disponible ✅	Non ✅	✅ Conforme
Brevo Email	Sous-traitant Art. 28	AWS Irlande + FR, UE ✅	À signer ⚠️	Non ✅	✅ Conforme (DPA à signer)
Brevo SMS	Sous-traitant Art. 28	UE ✅	À signer ⚠️	Non ✅	✅ Conforme (DPA à signer)